

Threat Detection Model: Payroll Fraud and Account Takeover Detection Strategy

Author: Colin Tarkington

Project: Objective 1, Threat Detection Model

Platform and Tools: Microsoft Sentinel, KQL, MITRE ATT&Ck Framework

Threat Focus: Storm-2657 (Payroll Pirates) and Similar Financially Motivated Threat Actors

Summary

This threat detection model was developed to identify and detect attack techniques commonly associated with payroll fraud campaigns, account takeover attempts, and post-compromise activity within a Microsoft 365 and Entra ID environment.

The threat model focuses on tactics used by financially motivated threat actors such as Storm-2657 (Payroll Pirates), who target employee credentials through phishing and adversary-in-the-middle (AiTM) techniques. Once access is obtained, attackers often establish persistence, manipulate authentication methods, create inbox rules to avoid detection, elevate privileges, and ultimately attempt to gain access to payroll or HR-related systems.

The objective of this detection strategy is to identify indicators of compromise as early as possible and provide defenders with actionable alerts before payroll manipulation or other business-impacting actions occur.

Threat Overview

Threat Actor: Storm-2657 (Payroll Pirates)

Motivation: Financial gain through payroll fraud, direct deposit manipulation, and account compromise.

Potential Impact to Shaw:

- Payroll fraud
- Unauthorized direct deposit changes
- Unauthorized access to sensitive employee information
- Business disruption

- Financial losses
- Compliance concerns

Attack Mapping to MITRE Framework

Detection Use Case	Data Source	MITRE ATT&CK Mapping	Severity
Risky Authentication	SigninLogs	T1078 – Valid Accounts	Medium
Account Takeover Activity	AuditLogs	T1098 – Account Manipulation	High
Repeated Risky Sign-In	SigninLogs	T1078 – Valid Accounts	Medium
MFA Registration	AuditLogs	T1098 – Account Manipulation and T1556 – Modify Authentication Process	High
Inbox Rule Creation	OfficeActivity	T1114.003 – Email Forwarding Rule	High
Suspicious PowerShell	DeviceProcessEvents	T1059.001 – PowerShell	High
Role Assignment Monitoring	AuditLogs	T1098 – Account Manipulation and potentially T1078 – Valid Accounts	Critical

Threat Scenario

1. Initial Access

Attackers deliver phishing emails designed to steal credentials.

2. Credential Compromise

Victims submit credentials to malicious login pages.

3. Successful Authentication

Attackers access Microsoft 365 accounts using stolen credentials.

4. Persistence

Attackers register MFA methods, add authentication devices, or change passwords.

5. Defense Evasion

Attackers create inbox rules to hide communications and security alerts.

6. Privilege Escalation

Attackers attempt to obtain elevated permissions.

7. Business Objective

Attackers target payroll systems and attempt payroll fraud.

KQL Detection Queries

Detection Use Case #1 – Risky Authentication Followed by Cloud Activity

Objective: Identify users who successfully authenticate despite medium or high-risk scores and access multiple cloud applications.

Data Source: SigninLogs

Query:

```
SigninLogs
| where TimeGenerated > ago(24h)
| where ResultType == 0
| where RiskLevelDuringSignIn in ("high","medium")
| summarize
    FirstSeen=min(TimeGenerated),
    LastSeen=max(TimeGenerated),
    ApplicationsAccessed=make_set(AppDisplayName),
    IPAddresses=make_set(IPAddress)
    by UserPrincipalName
| extend AppCount = array_length(ApplicationsAccessed)
| where AppCount >= 2
| project
    UserPrincipalName,
    FirstSeen,
    LastSeen,
    AppCount,
    ApplicationsAccessed,
    IPAddresses
| order by LastSeen desc
```

Detection Use Case #2 – Account Takeover Activities

Objective: Detect password changes, authentication changes, and account modifications.

Data Source: AuditLogs

Query:

```
AuditLogs
| where TimeGenerated > ago(24h)
| where OperationName has_any (
    "Update user",
    "Change password",
    "Reset password",
    "Add authentication method",
    "Register security info"
)
| project
    TimeGenerated,
    OperationName,
    Result,
    InitiatedBy,
    TargetResources
| order by TimeGenerated desc
```

Detection Use Case #3 – Repeated Risky Sign-In Activity

Objective: Identify accounts repeatedly authenticating despite risk indicators.

Data Source: SigninLogs

Query:

```
SigninLogs
| where TimeGenerated > ago(24h)
| where ResultType == 0
| where RiskLevelDuringSignIn in ("high","medium")
| summarize
    SignInCount=count(),
    FirstSeen=min(TimeGenerated),
    LastSeen=max(TimeGenerated)
    by UserPrincipalName,
    IPAddress,
    Location
| where SignInCount >= 5
| project
    LastSeen,
    UserPrincipalName,
```

IPAddress,
Location,
SignInCount
| order by SignInCount desc

Detection Use Case #4 – MFA Registration Monitoring

Objective: Detect new MFA registrations and authentication method additions.

Data Source: AuditLogs

Query:

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName has_any ("authentication method", "MFA", "security info",
"register")
    or ActivityDisplayName has_any ("authentication method", "MFA", "security info",
"register")
| extend TargetUser = tostring(parse_json(TargetResources)[0].userPrincipalName)
| project
    TimeGenerated,
    TargetUser,
    OperationName,
    ActivityDisplayName,
    InitiatedBy = tostring(InitiatedBy.user.userPrincipalName),
    Result
| order by TimeGenerated desc
```

Detection Use Case #5 – Suspicious Inbox Rule Creation

Objective: Detect mailbox rule creation and modification used to hide attacker activity.

Data Source: OfficeActivity

Query:

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where Operation in ("New-InboxRule", "Set-InboxRule", "UpdateInboxRules")
| extend UserPrincipalName = tostring(UserId)
| project
    TimeGenerated,
    UserPrincipalName,
    Operation,
    Parameters,
```

ClientIP
| order by TimeGenerated desc

Detection Use Case #6 – Suspicious PowerShell Execution

Objective: Detect potentially malicious PowerShell execution patterns.

Data Source: DeviceProcessEvents

Query:

```
DeviceProcessEvents
| where TimeGenerated > ago(1d)
| where FileName in ("powershell.exe", "pwsh.exe")
| where ProcessCommandLine has_any (
    "-enc",
    "-encodedcommand",
    "-nop",
    "-nopprofile",
    "-windowstyle hidden",
    "iex",
    "invoke-expression",
    "downloadstring",
    "bypass",
    "frombase64string"
)
| project
    TimeGenerated,
    DeviceName,
    AccountName,
    ProcessCommandLine,
    InitiatingProcessFileName
| order by TimeGenerated desc
```

Detection Use Case #7 – Privileged Role Assignment Monitoring

Objective: Detect assignment of privileged Entra ID roles.

Data Source: AuditLogs

Query:

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName has_any ("Add member to role", "Add role assignment")
| extend TargetUser = tostring(parse_json(TargetResources)[0].userPrincipalName)
| extend TargetRole = tostring(parse_json(TargetResources)[0].displayName)
```

```
| extend InitiatedBy = tostring(InitiatedBy.user.userPrincipalName)
| project
    TimeGenerated,
    InitiatedBy,
    TargetUser,
    TargetRole,
    OperationName,
    Result
| order by TimeGenerated desc
```

Conclusion

This project aimed to develop a threat detection model focused on account takeover, persistence, privilege escalation, and payroll fraud activities that could realistically impact Shaw Industries. Using Microsoft Sentinel telemetry, seven detection use cases were created to provide visibility across multiple stages of the attack lifecycle, including initial access, account compromise, persistence, defense evasion, privilege escalation, and malicious execution.

While the detection strategy was designed around tactics and techniques associated with Storm-2657 (Payroll Pirates), the resulting detections provide broader coverage against modern identity-focused threats targeting Microsoft 365 environments. By leveraging multiple Sentinel data sources, including SigninLogs, AuditLogs, OfficeActivity, and DeviceProcessEvents, this model implements a layered detection approach that enhances the organization's ability to identify suspicious activity, investigate potential compromises, and respond to threats before significant business impact occurs.

The detections developed through this project improve visibility into high-risk authentication events, account manipulation, unauthorized MFA registration, mailbox abuse, privilege escalation, and suspicious endpoint activity. Collectively, these detections provide practical and actionable monitoring capabilities that strengthen Shaw's overall security operations and support proactive threat detection efforts.